AegisAI Enterprise · Diccionarios de Datos, Flujos de Información y Repositorios

Arquitectura de Datos As-Built · Esquemas Tipados (TypeScript / Firestore Rules) · Orquestación Map-Reduce Multi-Normativa · Persistencia Dual Resiliente (Cloud Firestore + Local FS + tmpfs + RAM)

DICCIONARIOS / MODELOS **15 Esquemas** · 120 Campos | CLOUD FIRESTORE **aegis-ai-db** · 8 Colecciones (nam5) | REPOSITORIOS **20 Almacenes** en 5 Capas | FLUJOS DE INFORMACIÓN **10 Etapas E2E** · SSE + Map-Reduce | INTEGRIDAD & AUDITORÍA **SHA-256 (C01.4)** + WORM Inmutable | GOBERNANZA PII & RBAC **TLS 1.3** · **AES-256** · Multi-Tenant

1 · FLUJOS DE INFORMACIÓN END-TO-END (INGESTA MULTIMODAL, VALIDACIÓN ZERO-TRUST, EVALUACIÓN MAP-REDUCE, PERSISTENCIA DUAL Y STREAMING SSE)

10 etapas secuenciales y reactivas que transforman evidencia arquitectónica y telemetría GCP en dictámenes inmutables

F-01 Ingesta Multimodal

React 19 SPA / API v1 → Express

- `POST /api/evaluate` y `/v1/audits`
- Payload `AuditRequestPayload` + Multipart ≤30 MB
- Extracción en RAM: `pdf-parse` (.pdf) y `JSZip` (.zip, .md, .json, .yaml, código)
- Aislamiento en sandbox XML `<user_candidate_architecture>`

Origen: Cliente Web / CI-CD — DD-1 · RAM

F-02 Identidad Zero-Trust

Cloud IAP + Firebase Auth + API Key

- `extractUserSecurityContext(req)` valida cabeceras
- Verifica JWT Firebase o `x-goog-authenticated-user-email`
- Valida `x-api-key` (`aisvs_*`) en `/apiKeys`
- Comparación en tiempo constante SHA-256 (`C05.3`)

Genera: UserSecurityContext — DD-5 · DD-8

F-03 Guardrails y Anti-DoW

Inspección Crescendo + Cuotas + SSRF

- `inspectPromptAndTrackSession()` (ventana 15m, score <115)
- `acquireAntiDoWQuota()` : máx 30 req/15m, 3 evals, 2.5M tok
- `validateOutboundEndpoint()` bloquea IMDS `169.254.169.254`
- Sanitización inline con **Google Cloud Model Armor**

Control: C02.10 · C04.3 · C11.1 — DD-9 · RAM

F-04 Escaneo GCP en Vivo

Zero-Footprint Read-Only Scanner

- `POST /api/gcp/scan` y `/api/gcp/audit`
- Modos: ADC (Cloud Run SA), OAuth Token o JSON Key en RAM
- Inspecciona IAM, GCS, Cloud Run, Vertex AI, KMS, Secrets y Logs
- Sintetiza `GCPScanTelemetry` y manifiesto Markdown

Origen: APIs GCP Read-Only — DD-7 · R-5

F-05 Catálogos y BYOF SHA-256

Verificación Criptográfica e Ingesta

- `verifyNormativeSnapshotsIntegrity()` valida SHA-256 (`C01.4`)
- Carga catálogos desde `/app/config/frameworks` y `/tmp`
- `POST /api/frameworks/ingest` descompone leyes con IA
- Filtra marcos por ACL de dominio `allowedDomains` (`C08.1`)

Lectura: R-1 · R-2 · R-3 · R-4 — DD-3 · DD-4

F-06 Motor Map-Reduce IA

Evaluación Paralela Multi-Normativa

- **MAP**: Particiona capítulos en 3–4 lotes concurrentes
- `executeAIWithFallback()` → Vertex AI Gemini / OpenRouter / Local
- Determinismo estricto: `temperature: 0.0` , JSON Schema
- **REDUCE**: Calcula `overallScore` , nivel `L1-L3` y desglose

Motor: Gemini 3.8 / Multi-LLM — DD-1 · DD-2

F-07 Síntesis de Remediación

Generador de Arquitectura 100%

- `generateRemediatedArchitecture()` post-evaluación
- Integra controles `Fallido` y `Falta Evidencia`
- Aplica herencia de plataforma `PlatformProfile` (SaaS/PaaS)
- Genera guía 4D (`RemediationGuidance`) + doc ≤200 KB

Salida: remediatedArchitectureDoc — DD-1 · DD-2

F-08 Persistencia Dual + Saga

Coordinador Transaccional C09.4

- `runCompensatingSaga()` asegura atomicidad o rollback
- Escritura primaria en Firestore `/audits` y `/asyncAudits`
- Espejo en caché efímero `/tmp/aegis-runtime-cache`
- Inmutabilidad WORM en dictámenes (`allow delete: if false`)

Destino: Firestore nam5 + /tmp — R-1 · R-3

F-09 Streaming SSE y Reportes

Canal Reactivo y Exportación Ejecutiva

- Stream `text/event-stream` con latidos cada 12s
- Sincronización en vivo `onSnapshot(db, 'audits')` en UI
- Notificación opcional vía `webhookUrl` en API asincrona
- Exportación cliente: Dictamen PDF (`jsPDF`), Plan RACI y `.md`

Destino: Cliente React / Webhook — DD-1 · UI

F-10 Telemetría AIMS y SIEM

Observabilidad continua y SOC Alerting

- `recordAimsEvaluationMetrics()` mide ctias literales (SLO ≥95%)
- `emitSecurityAlert()` despacha 8 tipos de alertas críticas
- Persiste en Firestore `/security_alerts` y Cloud Logging
- Envía hallazgos a **SCC AI Protection** y `SECURITY_ALERT_WEBHOOK_URL`

Destino: Cloud Logging / SIEM — DD-8 · DD-9

Saga Write /audits

/security_alerts

2 · DICCIONARIOS DE DATOS Y ESQUEMAS DE ENTIDADES (SRC/TYPES.TS · SERVER.TS · FIRESTORE.RULES · FIREBASE-BLUEPRINT.JSON)

Definición exhaustiva de atributos, tipos de datos, restricciones de longitud/formato, llaves primarias, clasificación PII y mutabilidad

DD-01 · AuditReport

Colección Firestore: /audits/{auditId} · Entidad Primaria de Dictamen

WORM · 26 ATRIBUTOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`id` PK	`string`	`<= 128` · Obligatorio	INMUTABLE	Identificador único del dictamen (inmutable en updates).
`date`	`string`	`ISO-8601 <= 100` · Oblig.	Público Interno	Fecha/hora UTC de ejecución de la auditoría.
`systemName`	`string`	`1..500 chars` · Oblig.	Interno	Nombre del sistema o arquitectura de IA auditada.
`technicalLead`	`string`	`<= 200 chars` · Opcional	PII NOMBRE	Nombre del líder técnico o arquitecto responsable.
`email`	`string`	`<= 200 chars` · Opcional	PII EMAIL	Correo electrónico de contacto para seguimiento.
`description`	`string`	`<= 100,000 chars` · Oblig.	CONFIDENCIAL	Manifiesto de arquitectura y evidencia técnica consolidada.
`overallScore`	`number`	`0 .. 100` · Obligatorio	Interno	Calificación global ponderada de cumplimiento (%).
`executiveSummary`	`string`	`<= 100,000 chars` · Oblig.	Confidencial	Resumen ejecutivo de brechas y postura de riesgo.
`chapters`	`AISVSChapter[]`	`list <= 500` · Oblig.	Confidencial	Arreglo de capítulos evaluados y controles probados.
`standard / standards`	`enum / string[]`	`AI-SVS | ISO-42001 | FULL | CUSTOM | MULTI`	Interno	Normativa primaria o lista multi-estándar seleccionada.
`standardsBreakdown`	`Breakdown[]`	`list <= 20` · Opcional	Interno	Métricas por estándar: `score, passed, failed, missing` .
`customFrameworkId`	`string` FK	`<= 200 chars` · Opcional	Interno	Referencia al marco personalizado en `custom_frameworks` .
`targetLevel / assessedLevel`	`enum`	`AUTO | L1 | L2 | L3`	Interno	Nivel de madurez objetivo vs. nivel real alcanzado.
`techPlatform / deploymentType`	`string / enum`	`SaaS | PaaS | Self-Hosted | Hybrid`	Interno	Plataforma base (Vertex AI, Gemini, Bedrock, Azure, On-Prem).
`remediatedArchitectureDoc`	`string`	`<= 200,000 chars` · Opc.	CONFIDENCIAL	Documento Markdown de Arquitectura Remediada al 100%.
`isLiveGcpScan / gcpProjectId`	`bool / string`	`<= 200 chars` · Opcional	Confidencial	Bandera e ID de proyecto de escaneo GCP en vivo.
`gcpTelemetry`	`GCPScanTelemetry`	`map` · Opcional	Confidencial	Inventario y hallazgos recolectados en vivo desde GCP.
`ownerUid / ownerEmail / tenantDomain`	`string`	`<= 200 chars` · Inmutable	PII / RBAC	Propiedad multi-tenant verificada por IAP / Firebase Auth.
`modelUsed / latencyMs / *Tokens`	`string / number`	`0..100,000,000` · Opc.	Telemetría	Modelo LLM utilizado, latencia (ms) y tokens consumidos.

DD-02 · AISVSChapter · PuntoProbado · RemediationGuidance

Sub-esquemas anidados en AuditReport.chapters[] · Evaluación por control y Guía 4D

SUB-ESQUEMA · 20 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`chapterId / chapterName`	`string`	`1..200 chars` · Oblig.	Interno	ID (ej. `C1, ISO-A.6`) y título del capítulo evaluado.
`standardId / remediated`	`string / bool`	Opcional	Interno	Marco origen del capítulo e indicador de remediación.
`puntosProbados[].id` PK	`string`	`ej. C1.1.1, A.6.2.6` · Oblig.	Interno	Código oficial del control normativo auditado.
`puntosProbados[].status`	`enum`	`Aprobado | Fallido | Falta Evidencia`	Crítico	Veredicto determinista basado en evidencia documental.
`level / isMandatoryForTargetLevel`	`enum / bool`	`L1 | L2 | L3` · Oblig.	Interno	Nivel de aseguramiento del control y obligatoriedad.
`isInheritedFromPlatform`	`boolean`	+ `inheritedPlatformName`	Interno	Indica si el control se hereda del proveedor Cloud (SaaS/PaaS).
`comoSeAprobo / comoFallo`	`string`	Justificación técnica · Oblig.	Confidencial	Explicación forense del cumplimiento o brecha detectada.
`fuenteEvidencia / textoEvidencia`	`string`	Cita textual verificable · Oblig.	ANTI-ALUCINACIÓN	Sección/archivo fuente y fragmento literal extraído.
`riskImpact / remediation`	`enum / string`	`Alto | Medio | Bajo` Oblig.	Confidencial	Severidad del riesgo y resumen ejecutivo de mitigación.
`remediationDetails.strategy`	`string`	Guía 4D · Opcional	Confidencial	Estrategia arquitectónica detallada de remediación.
`remediationDetails.actionableSteps`	`string[]`	Lista ordenada (3–5 pasos)	Confidencial	Pasos técnicos accionables de implementación.
`codeOrConfigExample / verificationRecipe`	`string`	Snippet Terraform/YAML/TS + Test	Confidencial	Código listo para producción y receta de verificación.
`effortLevel / recommendedTools`	`enum / string[]`	`Bajo(1-3d) | Medio(1-2s) | Alto(>2s)`	Interno	Estimación de esfuerzo e inventario de herramientas.

DD-03 · StandardChapter & StandardControl

Colecciones: /standards_aisvs/{id} (90 ctrls) · /standards_iso42001/{id} (38 ctrls) · src/lib/*Data.ts

CATÁLOGO · 14 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`chapterId` PK	`string`	`== docId (<= 32 chars)`	INMUTABLE	ID del capítulo normativo (ej. `C01..C12, CLAUSE-4, ANNEX-A`).
`title`	`string`	`1..200 chars` · Oblig.	Público	Título oficial del dominio o cláusula normativa.
`shortDescription`	`string`	`<= 1,000 chars` · Oblig.	Público	Resumen ejecutivo del objetivo de seguridad del capítulo.
`fullDescription`	`string`	`<= 10,000 chars` · Oblig.	Público	Descripción normativa completa e intención arquitectónica.
`order`	`number`	Entero secuencial · Opcional	Público	Orden de visualización y particionamiento en lotes Map-Reduce.
`controls`	`StandardControl[]`	`list <= 200` · Oblig.	Público	Lista de controles verificables pertenecientes al capítulo.
`controls[].id` PK / `title`	`string`	Código oficial + nombre	Público	Identificador único del control y nombre descriptivo.
`controls[].description / level`	`string / enum`	Requisito + `L1 | L2 | L3`	Público	Requisito normativo verificable y nivel de madurez exigible.
`objective / *Guidance`	`string`	Guía de auditoría y remediación	Público	Objetivo de control, criterios de prueba y guía de mitigación.

DD-04 · CustomFramework & SnapshotIntegrityStatus

Firestore: /custom_frameworks/{id} · Local FS: config/frameworks/*.json · Caché: /tmp/aegis-runtime-cache

BYOF + SHA-256 · 18 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`id` PK	`string`	`^[a-zA-Z0-9_\-\.]+$`	PK DUAL	ID del marco (ej. `fw-1fpdppp-mex-2026` , `fw-eu-ai-act-*`).
`shortCode / version`	`string`	`ej. LFPDPPP-MX, v1.0`	Público Interno	Código corto para badges UI y versión de la regulación.
`name / jurisdiction`	`string`	Nombre oficial + país/región	Público Interno	Nombre de la ley/estándar y jurisdicción legal (México, UE, Global).
`description`	`string`	Resumen legal y técnico	Público Interno	Alcance normativo extraído durante la ingesta BYOF.
`createdAt / createdBy`	`string`	`ISO-8601` + Email autor	PII AUTOR	Fecha de creación e identidad del usuario que subió el marco.
`totalChapters / totalControls`	`number`	Conteos enteros >= 1	Interno	Total de capítulos y controles estructurados por Gemini.
`chapters`	`StandardChapter[]`	Estructura jerárquica completa	Interno	Capítulos y controles descompuestos del documento legal.
`allowedDomains / tenantDomain`	`string[] / string`	Filtro ACL Multi-Tenant (`C08.1`)	ACL TENANT	Dominios autorizados para consultar y auditar con este marco.
`sha256Signature`	`string`	`64 hex chars (SHA-256)`	FIRMA C01.4	Resumen criptográfico SHA-256 calculado sobre `id+shortCode+chapters` .
`SnapshotIntegrityStatus`	`interface`	`verified, checkedAt, mismatches[]`	Seguridad	Estado de verificación SHA-256 contra `integrity-manifest.json` .

DD-05 · ApiKey & AsyncAuditJob (Motor API v1 CI/CD)

Colecciones Firestore: /apiKeys/{keyId} (Cliente+Servidor) y /asyncAudits/{jobId} (Solo Admin SDK)

API & JOBS · 21 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`ApiKey.id / key` PK	`string`	`^aisvs_[a-zA-Z0-9]{32,64}$`	SECRETO API	Llave API para CI/CD; `docId == key` , sin updates permitidos.
`ApiKey.name`	`string`	`1..200 chars` · Oblig.	Interno	Etiqueta descriptiva del pipeline o integración CI/CD.
`createdAt / lastUsedAt`	`string`	`ISO-8601 <= 100 chars`	Interno	Marcas de tiempo de emisión y último uso en `/api/v1/audits` .
`ApiKey.status`	`enum`	`active | revoked`	Seguridad	Estado de vigencia; revocación inmediata mediante borrado.
`ownerUid / ownerEmail / tenantDomain`	`string`	Identidad propietaria RBAC	PII / RBAC	Restringe borrado en `firestore.rules` al dueño o admin.
`AsyncAuditJob.id` PK	`string`	`job_<ts>_<rand>`	Interno	ID de trabajo asincrono devuelto con código `HTTP 202 Accepted` .
`AsyncAuditJob.status`	`enum`	`PROCESSING | COMPLETED | FAILED`	Interno	Estado del ciclo de vida en la cola `/asyncAudits/{jobId}` .
`systemName / technicalLead / email`	`string`	Metadatos del sistema auditado	PII CONTACTO	Datos del sistema y responsable enviados vía API programática.
`standard / customFrameworkId`	`string`	Normativa objetivo del job	Interno	Marco regulatorio evaluado en segundo plano.
`webhookUrl`	`string`	URL HTTPS validada por SSRF guard	Confidencial	Endpoint de callback notificado al concluir la auditoría.
`result / error`	`AuditReport / str`	Dictamen final o mensaje de fallo	Confidencial	Resultado completo sincronizado también en `/audits/{id}` .

DD-06 · AdminSettings & PlatformProfile (Gobernanza Multi-LLM)

Firestore: /system_config/admin_settings · Local: config/admin-settings.json · Caché: /tmp/aegis-runtime-cache

CONFIG & HERENCIA · 20 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`provider`	`enum`	`gemini | anthropic | openrouter | openai | custom`	Configuración	Proveedor activo de IA para el motor Map-Reduce.
`geminiBackend`	`enum`	`vertex_ai | api_key`	Configuración	Selecciona Vertex AI Enterprise (ADC/IAM) o Gemini Developer API.
`geminiApiKey / maskedKey`	`string`	Enmascarado `AIzaSy...xxxx` en UI	SECRETO CRÍTICO	Llave API Gemini (inyectada desde Secret Manager o Admin UI).
`preferredModel / fallbackModel`	`string`	`ej. gemini-3.8-flash`	Configuración	Modelo primario y modelo de respaldo automático ante errores 429/5xx.
`openaiApiKey / maskedOpenaiKey`	`string`	Enmascarado `sk-...xxxx` en UI	SECRETO CRÍTICO	Credencial para OpenRouter, OpenAI, Anthropic o gateway corporativo.
`openaiBaseUrl / openaiModel`	`string`	Validado contra `ALLOWED_EGRESS_HOSTS`	Seguridad C04.3	Endpoint HTTPS compatible con OpenAI y identificador de modelo.
`customHeaders`	`Record<str,str>`	Cabeceras HTTP adicionales	Confidencial	Headers personalizados para proxies corporativos o gateways IA.
`temperature / maxTokens`	`number`	`0.0` (determinista) / `8192`	Gobernanza AIMS	Parámetros de inferencia para garantizar repetibilidad (SLO 100%).
`updatedAt / source`	`string`	`ISO-8601` + origen de hidratación	Auditoría	Marca de última modificación en Firestore `/system_config/admin_settings` .
`PlatformProfile (6 perfiles)`	`interface`	`key, name, provider, deploymentType`	Catálogo Base	Define `inheritedCapabilities[]` y `customerResponsibilities[]` .

DD-07 · GCPScanTelemetry & GCPResourceItem (Escáner GCP)

Generado por src/services/gcpScannerService.ts y embebido en AuditReport.gcpTelemetry

TELEMETRÍA CLOUD · 22 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`projectId / projectNumber`	`string`	ID y número de proyecto GCP	Confidencial	Proyecto Google Cloud inspeccionado en vivo.
`scanTime / authModeUsed`	`string / enum`	`adc | token | service_account | demo`	Auditoría	Timestamp UTC y mecanismo de autenticación efímera empleado.
`totalResourcesFound`	`number`	Conteo total de activos	Interno	Suma de recursos cloud e IA descubiertos en el proyecto.
`componentsScanned`	`string[]`	Lista de APIs consultadas	Interno	Servicios inspeccionados (IAM, GCS, Cloud Run, Vertex AI, KMS, Secrets).
`findingsSummary`	`object`	`critical, high, medium, low, info`	Crítico	Conteo agregado de hallazgos de postura de seguridad por severidad.
`resources.iamFindings`	`GCPResourceItem[]`	Políticas IAM y Service Accounts	Confidencial	Detecta roles primitivos (Owner/Editor), llaves SA y acceso público.
`resources.buckets / cloudRunServices`	`GCPResourceItem[]`	Buckets GCS y servicios Cloud Run	Confidencial	Verifica Public Access Prevention, Uniform Bucket Access, IAP y egress.
`resources.vertexEndpoints / Models`	`GCPResourceItem[]`	Activos Vertex AI en producción	Confidencial	Audita endpoints públicos vs. privados (PSC/VPC-SC) y linaje de modelos.
`resources.kmsKeys / secrets`	`GCPResourceItem[]`	Criptografía KMS y Secret Manager	Confidencial	Verifica rotación de claves CMEK y políticas de secretos.
`rawManifestMarkdown`	`string`	Bloque XML/Markdown inyectado	Confidencial	Manifiesto técnico inyectado al prompt del evaluador Map-Reduce.
`GCPResourceItem.*`	`interface`	`id, name, type, location, status, details`	Confidencial	Incluye `complianceImpact` y `recommendedControl` (AISVS/ISO).

DD-08 · SecurityAlertEvent & UserSecurityContext (SIEM & Auth)

Firestore: /security_alerts/{id} · Cloud Logging JSON · SCC AI Protection · Middleware C05.3/C12.2

SEGURIDAD & SOC · 12 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`SecurityAlertEvent.id` PK	`string`	`SEC-<timestamp>-<rand5>`	FORENSE	ID único de alerta en Firestore `/security_alerts` y Cloud Logging.
`timestamp`	`string`	`ISO-8601 UTC` · Obligatorio	Forense	Instante exacto del evento de seguridad detectado.
`eventType`	`enum (8 tipos)`	`PROMPT_INJECTION | SSRF | DOW | ...`	Crítico C12.2	Categoría mapeada a `scc4iProtection.findingCategory` .
`severity`	`enum`	`INFO | WARNING | CRITICAL`	Crítico	Nivel de severidad; `WARNING/CRITICAL` disparan SIEM Webhook.
`actor`	`string`	Email IAP/Firebase o `system`	PII ACTOR	Identidad autenticada asociada al evento o intento adversarial.
`ip`	`string`	`x-forwarded-for` / socket IP	PII RED	Dirección IP origen para correlación en SIEM y contafuegos.
`details`	`Record<str,any>`	Contexto estructurado JSON	Confidencial	Indicadores regex, puntajes de riesgo, pasos de saga o URLs bloqueadas.
`UserSecurityContext.authenticated`	`boolean`	Estado de sesión verificada	Seguridad	Resultado de verificación criptográfica de identidad por request.
`uid / email / tenantDomain`	`string`	Extraído de JWT o cabecera IAP	PII / RBAC	Atributos de identidad para aislamiento multi-tenant.
`authSource`	`enum`	`firebase_id_token | iap_header | api_key | anon`	Seguridad	Fuente de autenticación validada por el middleware Zero-Trust.

DD-09 · AimsTelemetryState · ClientQuotaWindow · SessionRiskState

Diccionarios de Estado en Memoria RAM (Node.js V8 Heap) · Expuesto en GET /api/admin/aims-telemetry y /api/security/pressure

ESTADO RAM · 20 CAMPOS

CAMPO / ATRIBUTO	TIPO	RESTRICCIÓN / REGLA	CLASIF.	DESCRIPCIÓN EN EL DICCIONARIO
`totalEvaluations / Batches`	`number`	Contadores acumulativos RAM	Telemetría AIMS	Total de auditorías y lotes Map-Reduce ejecutados por instancia.
`totalControlsEvaluated`	`number`	Controles inspeccionados	Telemetría AIMS	Total de puntos de control procesados en todos los marcos.
`controlsWithExactCitation`	`number`	Citas >10 chars verificadas	Calidad C08.4	Controles con fuente y texto de evidencia literal no vacío.
`citationGroundedRatePercent`	`number`	`SLO >= 95.0%` (ISO Cl. 9.1)	SLO Calidad	Porcentaje de fundamentación citatriz libre de alucinaciones.
`deterministicTempEnforcedCount`	`number`	`SLO == 100.0%` (temp=0.0)	SLO AIMS	Auditorías ejecutadas con determinismo estricto.
`avgLatencyMs / total*Tokens`	`number`	`SLO P95 <= 900,000 ms`	FinOps / Rend.	Latencia promedio y consumo acumulado de tokens (Prompt/Completion).
`ClientQuotaWindow.*` (`C11.1`)	`interface`	`requestCount<=30, active<=3, tok<=2.5M`	Anti-DoW RAM	Ventana móvil de 15 min por cliente para prevenir Denial-of-Wallet.
`SessionRiskState.*` (`C02.10`)	`interface`	`cumulativeRiskScore<115, flaggedTurns`	Anti-Crescendo	Rastreador multi-turno (15m); bloquea sesión 10m si detecta escalamiento.

3 · REPOSITORIOS DE DATOS DISPONIBLES (5 CAPAS DE PERSISTENCIA)

Cloud Firestore nam5 · Local FS R/O (/app/config) · Caché Efímero tmpfs · Catálogos Semilla · Bóvedas GCP

Capa 1 · Google Cloud Firestore Native (Base de Datos: aegis-ai-db · Multi-Región nam5)

Persistencia NoSQL serverless primaria · Cifrado AES-256 en reposo y TLS 1.3 en tránsito · Reglas declarativas en firestore.rules

8 COLECCIONES ACTIVAS

COLECCIÓN / RUTA FIRESTORE	DICCIONARIO ASOCIADO	ACCESO CLIENTE (WEB SDK)	ACCESO SERVIDOR (NODE.JS)	POLÍTICA DE GOBERNANZA, RETENCIÓN Y REGLAS DE SEGURIDAD
`/audits/{auditId}`	`AuditReport` (DD-01)	R / C / U (NO DELETE)	Admin SDK + Saga	Inmutable WORM · Dominio verificado + validación estricta de esquema.
`/standards_aisvs/{id}`	`StandardChapter` (DD-03)	R / C / U (NO DELETE)	Admin SDK	Catálogo en nube OWASP AISVS v1.0 (12 capítulos, 90 controles).
`/standards_iso42001/{id}`	`StandardChapter` (DD-03)	R / C / U (NO DELETE)	Admin SDK	Catálogo en nube ISO/IEC 42001:2023 (Cláusulas 4–10 y Anexo A, 38 ctrls).
`/apiKeys/{keyId}`	`ApiKey` (DD-05)	R / C / D (No Update)	Admin SDK (Auth v1)	Bóveda de llaves CI/CD (`aisvs_*`); borrado solo por dueño o admin.
`/custom_frameworks/{id}`	`CustomFramework` (DD-04)	DENEGADO (FALSE)	Solo Admin SDK	Marcos regulatorios BYOF con firma SHA-256 y ACL `allowedDomains` .
`/asyncAudits/{jobId}`	`AsyncAuditJob` (DD-05)	DENEGADO (FALSE)	Solo Admin SDK	Estado y resultados de auditorías asíncronas `/api/v1/audits` .
`/system_config/admin_settings`	`AdminSettings` (DD-06)	DENEGADO (FALSE)	Solo Admin SDK	Configuración activa del proveedor LLM hidratada al arranque.
`/security_alerts/{alertId}`	`SecurityAlertEvent` (DD-08)	DENEGADO (FALSE)	Solo Admin SDK	Registro forense de alertas de seguridad de IA y eventos C12.2.

Invariante Zero-Trust (firestore.rules): El acceso desde navegador exige `isAuthenticated()` con correo verificado perteneciente a `ALLOWED_DOMAINS` (`google.com`). Las colecciones administrativas y de back-office están 100% bloqueadas al cliente y operan exclusivamente vía **Firebase Admin SDK (ADC)**.

Capa 2 · Repositorio Local Inmutable (/app/config)

Sistema de archivos del contenedor endurecido en solo lectura (chmod -R a-w /app)

6 ARCHIVOS · SOLO LECTURA

RUTA DE ARCHIVO EN CONTENEDOR	ESQUEMA	CONTENIDO Y PROPÓSITO
`config/frameworks/fw-1fpdppp-mex-2026.json`	`CustomFramework`	LFPDPPP México / INAI (Protección de Datos Personales · 8 caps).
`config/frameworks/fw-1fpc-mex-2026.json`	`CustomFramework`	LFPC México / PROFECO (Protección al Consumidor en IA · 6 caps).
`config/frameworks/fw-eu-ai-act-mtug5x39.json`	`CustomFramework`	Reglamento Europeo de IA (EU AI Act 2024/1689 · Alto Riesgo).
`config/frameworks/fw-dsm-01-mubn2fty.json`	`CustomFramework`	Marco de Seguridad Corporativo DSM-01 pre-empaquetado.
`config/frameworks/integrity-manifest.json`	`Manifest SHA-256`	Hashes SHA-256 de referencia verificados al inicio (Control C01.4).
`config/admin-settings.json` & `firebase-*.json`	`AdminSettings`	Configuración semilla de proveedor LLM y enlace a proyecto Firebase.

Control OWASP AISVS C04.1: Ningún proceso en producción puede modificar `/app/config` ; previene persistencia de malware o alteración de catálogos.

Espejo Dual

Seed Fallback

Capa 3 · Caché Efímero tmpfs (/tmp/aegis-runtime-cache)

Patrón de Persistencia Dual Resiliente en memoria volátil del contenedor Cloud Run

PERSISTENCIA DUAL · TMPFS

RUTA / OPERACIÓN EN CACHÉ EFÍMERO	ESQUEMA	COMPORTAMIENTO OPERATIVO
`/tmp/aegis-runtime-cache/admin-settings.json`	`AdminSettings`	Espejo escribible en RAM de la configuración LLM activa.
`/tmp/aegis-runtime-cache/frameworks/*.json`	`CustomFramework`	Caché de baja latencia de marcos BYOF subidos o leídos de Firestore.
Mecanismo de Lectura (Read-Through):	`getCustomFramework`	`1º /tmp/cache → 2º /app/config → 3º Firestore` `custom_frameworks` .
Mecanismo de Escritura (Write-Through):	`saveCustomFramework`	Firma con SHA-256 → escribe en `/tmp/cache` → persiste en Firestore.

Alta Disponibilidad: Garantiza velocidad de lectura sub-milisegundo y continuidad total incluso en entornos aislados sin salida a Firestore.

Capa 4 · Catálogos Semilla y Contextos (src/lib/* & Raíz)

Artefactos estáticos compilados en el bundle TypeScript / Vite

8 MÓDULOS ESTÁTICOS

ARCHIVO / MÓDULO EN REPOSITORIO	TIPO / ESQUEMA	ROL EN EL FLUJO DE INFORMACIÓN
`owasp-aisvs-context.md`	`Markdown Raw`	Contexto íntegro OWASP AISVS v1.0 precargado en RAM para prompts.
`iso-42001-context.md`	`Markdown Raw`	Contexto íntegro ISO/IEC 42001:2023 precargado en RAM para prompts.
`src/lib/aisvsData.ts` & `iso42001Data.ts`	`StandardChapter[]`	Catálogos semilla tipados para hidratar la UI y poblar Firestore.
`src/lib/sampleAudits.ts` & `sampleAuditsEn.ts`	`AuditReport[]`	Dictámenes de referencia pre-construidos (bilingües ES / EN).
`src/lib/catalogTranslations.ts` & `translationsDict.ts`	`Record<str,any>`	Diccionarios de localización (ES / EN) de controles y cláusulas.

Capa 5 · Memoria RAM (V8 Heap) y Bóvedas Cloud GCP

Estado volátil de seguridad en tiempo real y servicios gestionados Google Cloud

5 ALMACENES RAM + GCP

REPOSITORIO EN MEMORIA / SERVICIO CLOUD	ESTRUCTURA	FUNCIÓN OPERATIVA Y DE SEGURIDAD
`RAM: clientQuotas` & `sessionRiskTracker`	`Map<string, State>`	Ventanas móviles de 15m para cuotas Anti-DoW (C11.1) y Crescendo (C02.10).
`RAM: aimsTelemetry` & `recentSecurityAlerts`	`State / RingBuffer[200]`	Métricas de calidad citatriz AIMS (C08.4) y buffer circular de alertas.
`RAM: multer.memoryStorage()`	`UploadedFileInput[]`	Buffers efímeros (≤30 MB) de PDFs/ZIPs descartados tras la evaluación.
`GCP Secret Manager`	`aegis-gemini-key / admin-token`	Bóveda HSM de secretos montada como variables de entorno en Cloud Run.
`GCP Cloud Logging & Artifact Registry`	`JSON Logs / Docker Img`	Auditoría estructurada (`aegis-security-alerting-c12-2`) e imágenes.

Gobernanza de Datos, Clasificación de Sensibilidad (PII / Secretos) y Leyenda Arquitectónica

Controles aplicados sobre el inventario de datos conforme a OWASP AI-SVS v1.0, ISO/IEC 42001:2023 y LFPDPPP México

INVENTARIO AUDITADO: 100%

GOBERNANZA DE DATOS, PRIVACIDAD (PII) Y RETENCIÓN

CATEGORÍA DE DATO	CAMPOS CLAVE	PROTECCIÓN Y CICLO DE VIDA
DATOS PERSONALES (PII)	`email, technicalLead, ownerEmail, actor, ip`	Cifrado TLS 1.3 + AES-256 · Acceso restringido por dominio IAP/Auth · LFPDPPP.
SECRETOS Y CREDENCIALES	`geminiApiKey, openaiApiKey, ApiKey.key`	Secret Manager · Enmascarado en API (`sk-...xxxx`) · Comparación SHA-256 constante.
EVIDENCIA Y DICTÁMENES	`description, chapters, remediatedArchitectureDoc`	Zero Data Retention en LLM · Regla WORM (`allow delete: if false`) en Firestore.

LEYENDA DE FLUJOS Y SÍMBOLOS DEL DIAGRAMA

- Flujo de datos e ingesta HTTP / SSE
- Flujo de inferencia IA Map-Reduce
- Persistencia y lectura en repositorios
- Validación Zero-Trust y alertas SOC
- Sincronización Persistencia Dual
- Relación de llave foránea / esquema

PK Llave Primaria / ID Documento — PII Dato Personal / Identificador

INMUTABLE Registro WORM (Sin borrado) — SECRETO Credencial / Contenido Protegido